

Informe de Pentesting — Actividad A08

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

1. Datos generales

Cliente: INSECUR S.A.

Contratista (alumno/a): Tomas Ortiz

DNI: 44907961

Username TryHackMe: ttomasortiz23

Email institucional: ttomasortiz23@gmail.com

Sala de elección (Nivel 2): kenobi

Branch en GitHub: ortiz-tomas

Fecha de inicio: 7 de octubre de 2026

Fecha de cierre: 9 de octubre 2026

2. Pre-pentesting

Alcance del trabajo

El alcance autorizado comprende exclusivamente las máquinas virtuales asignadas por la plataforma TryHackMe para la sala "Basic Pentesting" (núcleo obligatorio), identificadas durante las sesiones de trabajo por las direcciones IP 10.67.148.159, 10.65.172.34, 10.65.160.117 y 10.65.136.68 (la IP cambia en cada inicio de la máquina dentro del mismo laboratorio). Queda fuera de alcance cualquier sistema no provisto explícitamente por TryHackMe para esta actividad.

Reglas de Enfrentamiento (ROE)

Las pruebas se realizaron únicamente dentro del entorno aislado (sandbox) de TryHackMe, sin horarios restringidos por tratarse de un laboratorio propio. No se utilizaron técnicas destructivas (sin borrado de archivos del sistema objetivo, sin modificación de configuraciones críticas más allá de lo necesario para demostrar el acceso). Herramientas de fuerza bruta (Hydra) se limitaron a hilos moderados (-t 4 a -t 16) para evitar saturar el servicio SSH del laboratorio.

Autorización

Se declara que se cuenta con autorización expresa de la cátedra "Seguridad Aplicada a Sistemas de Información" (UCH) para operar sobre los entornos de TryHackMe indicados en la guía de la Actividad A08, conforme a la Carta de Autorización incluida en dicha guía.

Metodología utilizada

Se siguió el flujo profesional de pentesting propuesto por la cátedra (Preengagement, Reconocimiento, Escaneo, Enumeración, Explotación, Postexplotación, Reporte), alineado conceptualmente con las fases de PTES (Penetration Testing Execution Standard).

3. Durante: Hallazgos por fase

H-01 — Recurso SMB compartido sin autenticación (acceso anónimo)

Fase: Reconocimiento / Enumeración

Descripción: El servidor Samba expone un share llamado "Anonymous" accesible sin credenciales (sesión nula). Dentro se encontró el archivo staff.txt con nombres de usuarios reales del sistema (jan, kay).

Componente afectado: Servicio Samba smbd 4 (puertos 139/445)

Categoría (OWASP/CWE): CWE-284 (Control de acceso incorrecto)

CVE (si aplica): No aplica — error de configuración, no una vulnerabilidad de software

CVSS estimado: Medio

Evidencia: evidencias/enumeracion/staff.txt — comando: smbclient -L //<IP> -N

Herramienta utilizada: smbclient

Impacto en la Tríada CIA: Confidencialidad

Salvaguarda propuesta: Eliminar el acceso anónimo a los shares SMB; exigir autenticación para cualquier recurso compartido.

Riesgo residual tras aplicar: Bajo

H-02 — Divulgación de información en comentarios HTML y listado de directorios

Fase: Enumeración

Descripción: La página principal del sitio web (puerto 80) contiene un comentario HTML que referencia una sección de notas de desarrollo. El directorio /development/ tiene listado de archivos habilitado y expone dev.txt y j.txt con información interna (versión de Apache Struts 2.5.12, confirmación de que una contraseña fue crackeada fácilmente).

Componente afectado: Servidor web Apache httpd 2.4.41, directorio /development/

Categoría (OWASP/CWE): CWE-200 (Exposición de información sensible) / OWASP A05:2021 Security Misconfiguration

CVE (si aplica): No aplica

CVSS estimado: Medio

Evidencia: evidencias/enumeracion/desarrollo_web.txt — comandos: gobuster dir, curl

Herramienta utilizada: Gobuster, curl, navegador

Impacto en la Tríada CIA: Confidencialidad

Salvaguarda propuesta: Deshabilitar el listado de directorios en Apache; retirar comentarios y archivos de desarrollo de entornos accesibles públicamente.

Riesgo residual tras aplicar: Bajo

H-03 — Credenciales SSH débiles (usuario jan)

Fase: Explotación

Descripción: El usuario "jan", identificado a partir de staff.txt, posee una contraseña débil para el servicio SSH, obtenida mediante ataque de diccionario contra rockyou.txt.

Componente afectado: Servicio SSH (OpenSSH 8.2p1, puerto 22), cuenta jan

Categoría (OWASP/CWE): CWE-521 (Requisitos de contraseña débiles) / OWASP A07:2021 Identification and Authentication Failures

CVE (si aplica): No aplica

CVSS estimado: Alto

Evidencia: bitácora de comandos — Hydra, login exitoso registrado en consola (contraseña redactada en el informe)

Herramienta utilizada: Hydra

Impacto en la Tríada CIA: Confidencialidad, Integridad

Salvaguarda propuesta: Política de contraseñas robustas, autenticación por clave pública en lugar de contraseña, límite de intentos fallidos (fail2ban).

Riesgo residual tras aplicar: Bajo

H-04 — Clave privada SSH con permisos de lectura abiertos

Fase: Postexplotación / Explotación

Descripción: La clave privada SSH del usuario kay (/home/kay/.ssh/id_rsa) tiene permisos de lectura para otros usuarios del sistema (-rw-r--r--), permitiendo que jan la copie y la utilice para intentar autenticarse como kay.

Componente afectado: Sistema de archivos, cuenta kay

Categoría (OWASP/CWE): CWE-276 (Permisos por defecto incorrectos)

CVE (si aplica): No aplica

CVSS estimado: Alto

Evidencia: ls -la /home/kay/.ssh/ (permisos visibles en la bitácora)

Herramienta utilizada: ls, cat

Impacto en la Tríada CIA: Confidencialidad, Integridad

Salvaguarda propuesta: Restringir permisos de archivos de claves privadas a 600, propiedad exclusiva del usuario dueño.

Riesgo residual tras aplicar: Bajo

H-05 — Passphrase débil en clave SSH privada

Fase: Explotación

Descripción: La clave privada de kay está protegida con una passphrase, pero esta es débil y fue obtenida en segundos mediante fuerza bruta de diccionario con John the Ripper.

Componente afectado: Clave privada SSH de kay

Categoría (OWASP/CWE): CWE-521 (Requisitos de contraseña débiles)

CVE (si aplica): No aplica

CVSS estimado: Alto

Evidencia: ssh2john + john --wordlist=rockyou.txt (resultado registrado en bitácora, passphrase redactada en el informe)

Herramienta utilizada: ssh2john, John the Ripper

Impacto en la Tríada CIA: Confidencialidad, Integridad

Salvaguarda propuesta: Usar passphrases largas y únicas para proteger claves privadas; considerar el uso de un agente SSH con autenticación adicional.

Riesgo residual tras aplicar: Bajo

H-06 — Contraseña en texto claro guardada en archivo de respaldo

Fase: Postexplotación

Descripción: El archivo /home/kay/pass.bak contiene la contraseña real del usuario kay en texto plano.

Componente afectado: Cuenta kay, sistema de archivos

Categoría (OWASP/CWE): CWE-256 (Almacenamiento de contraseña en texto plano)

CVE (si aplica): No aplica

CVSS estimado: Alto

Evidencia: cat /home/kay/pass.bak (contenido redactado en el informe)

Herramienta utilizada: cat

Impacto en la Tríada CIA: Confidencialidad

Salvaguarda propuesta: Prohibir el almacenamiento de contraseñas en texto plano; usar gestores de contraseñas o secretos cifrados.

Riesgo residual tras aplicar: Bajo

H-07 — Privilegios sudo excesivos (escalada a root)

Fase: Postexplotación

Descripción: El usuario kay posee privilegios sudo sin restricciones (ALL : ALL) ALL, lo que permitió ejecutar cualquier comando como superusuario y obtener una shell de root completa.

Componente afectado: Configuración sudoers, cuenta kay

Categoría (OWASP/CWE): CWE-250 (Ejecución con privilegios innecesarios)

CVE (si aplica): No aplica

CVSS estimado: Crítico

Evidencia: sudo -l, sudo su, whoami, id (bitácora de comandos)

Herramienta utilizada: sudo, shell nativa

Impacto en la Tríada CIA: Confidencialidad, Integridad, Disponibilidad

Salvaguarda propuesta: Aplicar el principio de mínimo privilegio: otorgar a cada cuenta solo los comandos sudo estrictamente necesarios.

Riesgo residual tras aplicar: Bajo

H-08 — Versión de Apache Struts potencialmente vulnerable (sin explotación confirmada)

Fase: Enumeración

Descripción: La nota dev.txt menciona el uso de Apache Struts 2.5.12 con el plugin REST, una combinación con antecedentes de vulnerabilidades de deserialización conocidas en otras versiones. No se confirmó una instancia de Struts accesible en las rutas probadas (/struts2-rest-showcase/, /struts/ devolvieron HTTP 404), por lo que este hallazgo queda como informativo, no como explotación confirmada.

Componente afectado: Posible aplicación Struts (no confirmada en las rutas probadas)

Categoría (OWASP/CWE): Informativo — pendiente de confirmación

CVE (si aplica): A evaluar según versión exacta si se confirma la instancia

CVSS estimado: Bajo (hallazgo informativo, no confirmado)

Evidencia: evidencias/enumeracion/tomcat_rutas.txt, tomcat_rutas_adicionales.txt

Herramienta utilizada: curl, gobuster

Impacto en la Tríada CIA: No determinado (sin explotación confirmada)

Salvaguarda propuesta: Actualizar o retirar cualquier instancia de Struts expuesta; auditar rutas adicionales no probadas en esta sesión.

Riesgo residual tras aplicar: Bajo

4. Resumen ejecutivo de hallazgos

Crítico: 1 (H-07)

Alto: 4 (H-03, H-04, H-05, H-06)

Medio: 2 (H-01, H-02)

Bajo: 1 (H-08)

Total: 8 hallazgos (H-01 a H-08)

La cadena de explotación completa (acceso inicial por fuerza bruta SSH → pivoteo lateral mediante una clave privada mal protegida → escalada a root por privilegios sudo excesivos) demuestra que fallas individualmente de severidad media o alta pueden combinarse para producir un compromiso total del sistema. El hallazgo crítico (H-07) es consecuencia directa de una cadena de errores de configuración, no de una única vulnerabilidad de software.

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. Deshabilitar el acceso anónimo a los recursos SMB compartidos.
2. Desactivar el listado de directorios en Apache y retirar archivos de desarrollo del entorno de producción.
3. Forzar políticas de contraseñas robustas para todas las cuentas de usuario, incluyendo las passphrases de claves SSH.
4. Corregir los permisos de archivos de claves privadas SSH (600, propiedad del usuario).
5. Eliminar cualquier archivo que almacene contraseñas en texto plano (como pass.bak).
6. Revisar y restringir la configuración de sudoers aplicando el principio de mínimo privilegio.
7. Confirmar la versión exacta de Apache Struts en uso (si existe una instancia activa) y actualizarla o retirarla.

Recomendaciones administrativas (políticas y procesos)

1. Capacitar al personal técnico en buenas prácticas de gestión de secretos y contraseñas.
2. Establecer una política formal de revisión periódica de permisos de archivos sensibles.
3. Implementar revisiones de configuración (hardening) antes de poner en producción cualquier servidor.
4. Definir un proceso de gestión de vulnerabilidades que incluya el seguimiento de versiones de software de terceros (como Apache Struts).

6. Protocolo de Contingencia

Escenario de falla

Un atacante externo podría replicar la cadena de explotación documentada (fuerza bruta SSH → robo de clave privada → escalada a root) contra el entorno de producción de INSECUR S.A., obteniendo control total sobre el servidor afectado.

Impacto sobre la continuidad del negocio

De replicarse en producción, el compromiso de una cuenta con privilegios de administrador podría afectar la disponibilidad de los servicios web y de archivos compartidos de la organización, además de comprometer la confidencialidad de los datos almacenados, por un tiempo estimado de varias horas hasta la contención y recuperación completas.

Plan de respuesta

1. Activación: detección mediante monitoreo de intentos de autenticación fallidos repetidos (SSH) y alertas de acceso con privilegios elevados fuera de lo habitual.
2. Contención: aislar la máquina comprometida de la red, revocar las credenciales y claves afectadas, deshabilitar temporalmente las cuentas involucradas.
3. Recuperación: restaurar el servicio desde una copia de respaldo limpia o una imagen de servidor conocida como íntegra; rotar todas las credenciales del sistema.
4. Comunicación: notificar a dirección de TI y, de corresponder, a los responsables legales/compliance de la organización, según el protocolo interno de incidentes.
5. Post-mortem: documentar la causa raíz, las acciones tomadas y actualizar las políticas de seguridad para prevenir la recurrencia.

RTO y RPO estimados

RTO: 4 horas — tiempo estimado para aislar el servidor comprometido, restaurar desde una imagen limpia y verificar la integridad del sistema antes de volver a ponerlo en producción.

RPO: 24 horas — asumiendo backups diarios automáticos; en el peor caso se perdería hasta un día de datos (registros web, archivos compartidos) generados entre el último backup y el incidente.

7. Anexos

Anexo A — Bitácora de comandos

Ver archivo bitacora/basic_pentesting.txt en el repositorio de entrega, con el detalle cronológico de todos los comandos ejecutados durante las distintas sesiones de trabajo.

Anexo B — Capturas de pantalla y evidencias

Ver carpeta evidencias/ organizada por subcarpetas: reconocimiento/, escaneo/, enumeracion/, explotacion/, post/.

Anexo C — Hashes de las flags obtenidas

[COMPLETAR — formato: flag_id sha256_hash, generado con: `echo -n "thm{flag}" | sha256sum`]

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.